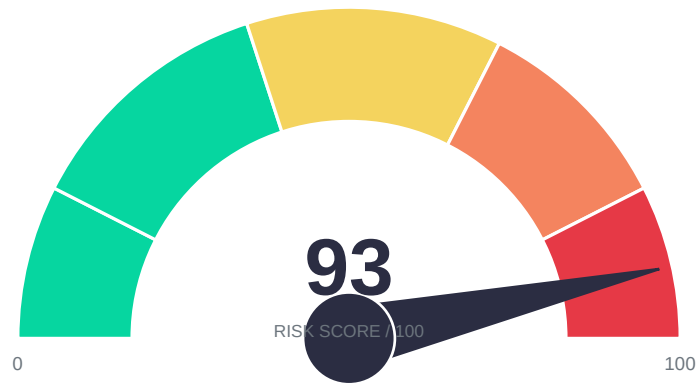


Penetration Testing Report

20/06/2026



GRADE F · CRITICAL

Prepared by:

RMW-PenStrike

Email:

contact@rmw-penstrike.com

This document is classified CONFIDENTIAL. It may not be copied without written permission.

Table of Contents

1. Executive Summary

1.1 Assessment Summary

1.2 Strategic Recommendations

2. Technical Summary

2.1 Scope

2.2 Post Assessment Clean-up

2.3 Risk Ratings

2.4 Findings Overview

3. Technical Details

3.1 Business Logic: Negative Quantity/Price Manipulation — CRITICAL

3.2 CSRF: Password Change via GET Request — CRITICAL

3.3 Unrestricted File Upload — HIGH

3.4 Prototype Pollution — MEDIUM

3.5 CORS Misconfiguration — MEDIUM

3.6 FTP Directory Exposure — MEDIUM

3.7 Information Disclosure via Admin Configuration Endpoint — MEDIUM

3.8 Potential SSRF via Product Image URL — MEDIUM

3.9 Information Disclosure via HTTP Headers — LOW

3.10 Missing Security Headers — LOW

3.11 Robots.txt Exposure — INFO

4. Appendices

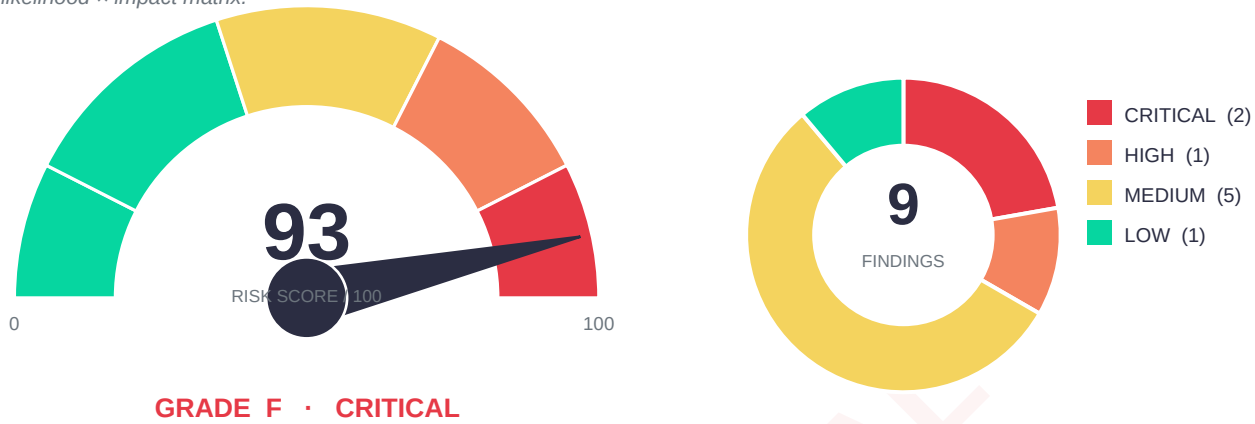
4.1 Penetration Testing Methodology

Threat Intelligence & Public Exploits

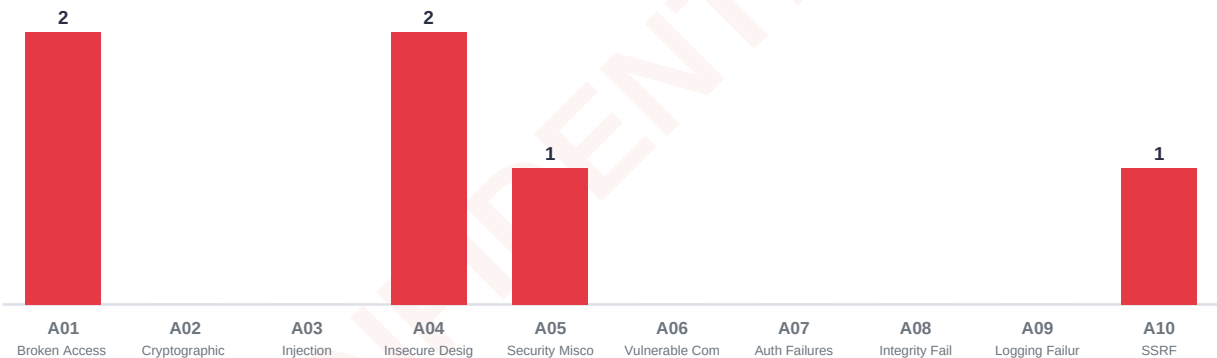
Remediation Roadmap

Risk Posture

At-a-glance security posture derived from all findings: overall risk score, severity distribution, OWASP Top 10 coverage, and a likelihood × impact matrix.

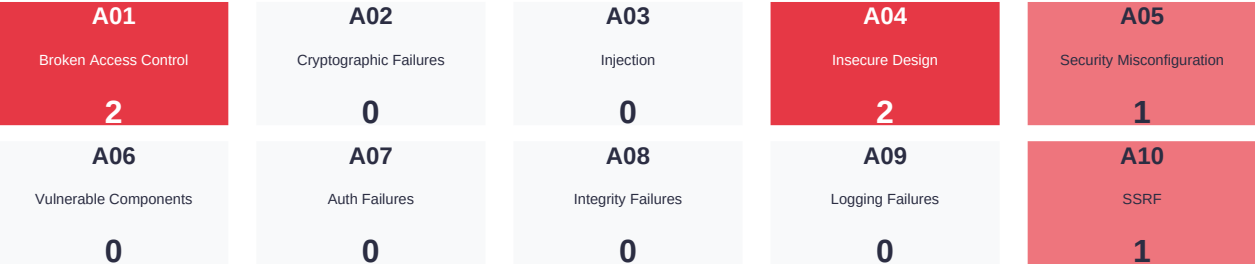


Findings by OWASP Top 10 Category



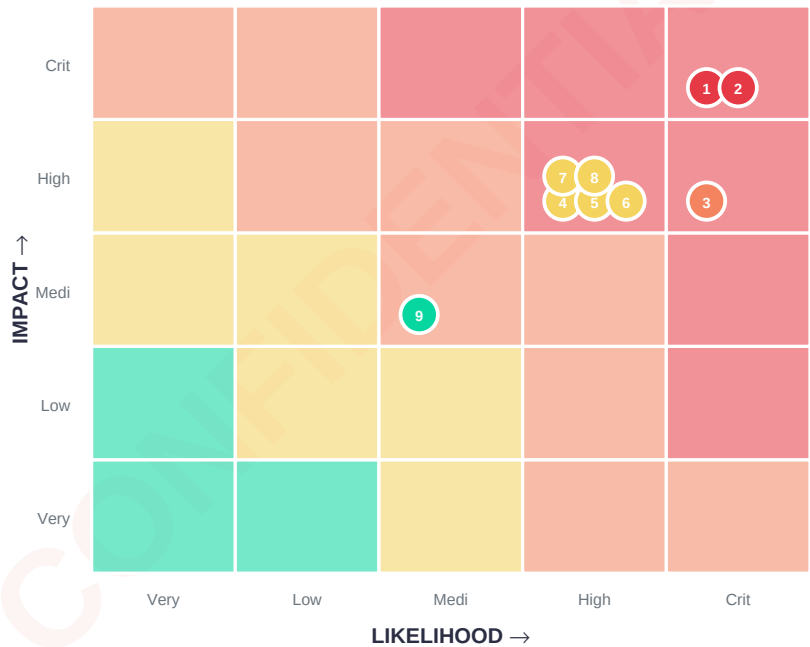
OWASP Top 10 Coverage Heatmap

Intensity reflects how many findings map to each OWASP 2021 category.

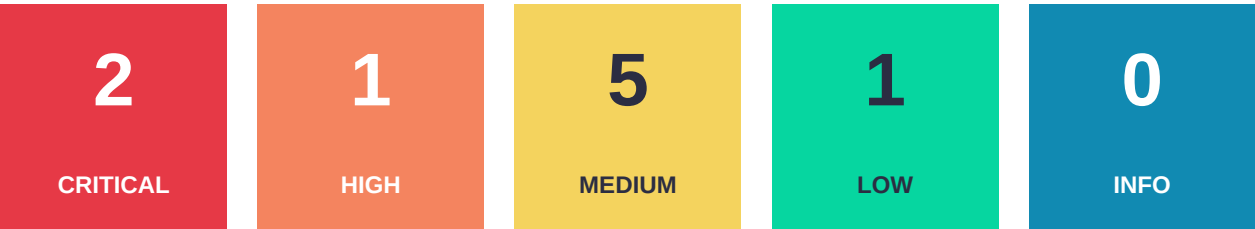


Risk Matrix — Likelihood × Impact

Each numbered dot is a finding (by its reference), positioned by severity. Upper-right (red) is the highest priority.



Vulnerability Summary



Total findings: 9

Penetration Testing Report

Date: 20 June 2026
Prepared by: RMW-PenStrike
Classification: Client Confidential

Document Control

Client Confidentiality
This document contains Client Confidential information and may not be copied without written permission.

Document Version Control

Issue No.	Issue Date	Issued By	Change Description
0.1	20 June 2026	RMW-PenStrike	Draft for internal review
1.0	20 June 2026	RMW-PenStrike	Released to client

Executive Summary

RMW-PenStrike was engaged to perform a web application penetration test against <https://demo.owasp-juice.shop/> to identify security weaknesses and assess the overall risk posture. The assessment uncovered multiple critical and high-severity vulnerabilities, including unprotected business logic that allows price manipulation, a cross-site request forgery flaw leading to full account takeover, and unrestricted

file upload that could result in remote code execution. Additionally, several medium-severity configuration weaknesses were identified, such as prototype pollution, overly permissive CORS, and information disclosure through an administrative endpoint. These findings collectively expose the application to significant risk of data theft, fraud, and system compromise. Immediate remediation is recommended for all critical and high-risk issues.

Assessment Summary

Overall risk level: **CRITICAL**

The combination of exploitable business logic and CSRF allows attackers to compromise user sessions and manipulate financial transactions without user interaction. Combined with unrestricted file upload and information leaks, an attacker could achieve full system compromise and lateral movement within the internal network.

Phase	Description	Critical	High	Medium	Low	Total
1	Web/API Penetration Testing	2	1	5	2	10

Strategic Recommendations

- **[CRITICAL]** Fix the CSRF vulnerability on the password change endpoint by implementing anti-CSRF tokens and requiring POST requests with origin validation.
- **[CRITICAL]** Strengthen business logic validation to prevent negative quantity manipulation and other parameter tampering attacks that could affect pricing or inventory.
- **[HIGH]** Enforce server-side file type verification, restrict allowed extensions, and store uploaded files outside the web root to prevent arbitrary code execution from file uploads.
- **[MEDIUM]** Harden the CORS configuration to restrict Access-Control-Allow-Origin to trusted domains and avoid wildcard origins that allow cross-site data theft.
- **[MEDIUM]** Remove the publicly accessible `/rest/admin/application-configuration` endpoint and ensure all administrative interfaces require authentication and authorisation.
- **[LOW]** Implement standard security headers (CSP, HSTS, X-Content-Type-Options) and sanitise prototype pollution vectors in JSON parsing to strengthen the application's defence-in-depth.

1. Technical Summary

1.1 Scope

The following target was included in this assessment:

- <https://demo.owasp-juice.shop/>

All testing was performed against this host. No internal network or additional applications were in scope.

1.2 Post Assessment Clean-up

Test accounts and artefacts created during the assessment (e.g., the user `test@test.com`, uploaded test files) should be disabled or removed as soon as possible. Any exploitation payloads that could affect production users should be reversed.

1.3 Risk Ratings

#	Risk Rating	CVSSv3 Score	Description
1	CRITICAL	9.0 - 10	Requires resolution as quickly as possible.
2	HIGH	7.0 - 8.9	Requires resolution in a short term.
3	MEDIUM	4.0 - 6.9	Should be resolved throughout ongoing maintenance.
4	LOW	1.0 - 3.9	Should be addressed as part of routine maintenance.
5	INFO	0 - 0.9	Reported for information only.

1.4 Findings Overview

Ref	Description	Risk
PT-1-1	Business Logic: Negative Quantity/Price Manipulation	CRITICAL
PT-1-2	CSRF: Password Change via GET Request	CRITICAL
PT-1-3	Unrestricted File Upload	HIGH
PT-1-4	Prototype Pollution	MEDIUM
PT-1-5	CORS Misconfiguration	MEDIUM
PT-1-6	FTP Directory Exposure	MEDIUM
PT-1-7	Information Disclosure via Admin Configuration Endpoint	MEDIUM
PT-1-8	Potential SSRF via Product Image URL	MEDIUM
PT-1-9	Information Disclosure via HTTP Headers	LOW
PT-1-10	Missing Security Headers	LOW

2. Technical Details

Ref ID: PT-1-1

Vulnerability Details

Evidence

[illegible]

Remediation Guidance

- Implement strict server-side validation that rejects negative quantities or any value below zero for all basket and order operations.
- Use unsigned numeric data types and enforce a minimum of 1 for orderable items.
- Add integrity checks for basket totals to ensure they are consistent with the sum of individual item prices.

Ref ID: PT-1-2

Vulnerability Details

Evidence

```
curl -s -k -X GET "https://demo.owasp-juice.shop//rest/user/change-password?current=admin123&new=hacked123&repeat=hacked123" -H "Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9"
```

```
eyJzdGF0dXMiOiJzdWJjZXNzIiwiaGF0YSI6eyJpZCI6MSwidXNlcm5hbWUiOiIiLCJlbWFPbCI6ImFkbWluQGp1aWNlLXNoLm9wIiwicGFzc3dvcmQIoiIwMTkyMDIzYTdiYmQ3MzI1MDUxNmYwNjlkZjE4YjUwMCIsInJvbGUiOiJhZG1pbiIsImRlbHV4ZVRva2VuIjoiiIiwibGFzdExvZ2luSXAiOiIiLCJwcm9maWxlSw1hZ2UiOiJhc3NldHMvchVibGJlL2ltYwdlcy91cGxvYWRzL2RlZmF1bHRBZG1pbi5wbmciLCJ0b3RwU2VjcmV0IjoiiIiwiaXNBY3RpdmUiOnRydWUsImNyZWZ0ZWRBdCI6IjIwMjYtMDYtMjAgMTU6NTU6NTguNzIxICswMDowMCIsImRlbGV0ZWRBdCI6bnVsbH0sImlhdCI6MTc4MTk3MTM5N30.wbEAS0K3ugpJlMY-Ev7NpfxT0q3DGKEaTugW0Ck37btZU1EfCxh8z9bgAiDqI2vL9UK3lZuYd4N72Dr5WTjvj64L24v-qB3j19j6lnC8BSQsE155MUMI15v0jWcGJegSP_Urdp9HUjyUskYIR20U0BfY_Gqo3jI1jtZ7cL3axCM"
```

A subsequent login attempt confirmed the password change:

```
curl -s -k -X POST "https://demo.owasp-juice.shop//rest/user/login" -d '{"email":"admin@juice-sh.op","password":"hacked123"}'
```

Remediation Guidance

- Change the endpoint to accept only POST requests and implement synchroniser token pattern (CSRF tokens) for all state-changing operations.
- Validate the Origin or Referer header to ensure requests originate from the same site.
- Do not transmit sensitive parameters (passwords) via the URL query string; use the request body and enforce HTTPS.

2.3 Unrestricted File Upload — HIGH

Ref ID: PT-1-3

The /file-upload endpoint accepts any file type without validation and stores the uploaded file in multiple publicly accessible directories with predictable URLs. An attacker could upload a malicious script (e.g., .php, .jsp, .aspx) and execute it via the web server, leading to remote code execution and full system compromise.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop//file-upload
Parameter(s)	File (multipart form)
Attack Vectors	Direct POST upload of executable file type
References	https://cwe.mitre.org/data/definitions/434.html

Evidence

A harmless text file (unique_870ec1b7-eeaa-4aed-8e6f-61e6fc62ba66.txt) was successfully uploaded and became accessible at multiple URLs:

```
POST https://demo.owasp-juice.shop//file-upload (multipart file) → HTTP 204
GET
https://demo.owasp-juice.shop//assets/uploads/unique_870ec1b7-eeaa-4aed-8e6f-61e6fc62ba66.txt
→ HTTP 200
GET
https://demo.owasp-juice.shop//public/uploads/unique_870ec1b7-eeaa-4aed-8e6f-61e6fc62ba66.txt
```

```
→ HTTP 200
GET https://demo.owasp-juice.shop//uploads/unique_870ec1b7-eeaa-4aed-8e6f-61e6fc62ba66.txt →
HTTP 200
```

No authentication or MIME type filter was required.

Remediation Guidance

- Validate file extensions against a strict allow-list (e.g., .jpg, .png, .pdf) and verify MIME types with content inspection.
- Store uploaded files outside the web document root and serve them via a dedicated handler that does not execute any server-side code.
- Implement authentication and authorisation for the upload endpoint to prevent anonymous misuse.

2.4 Prototype Pollution — MEDIUM

Ref ID: PT-1-4

The user registration endpoint (/api/Users) accepts JSON containing `__proto__` and `constructor.prototype` keys without sanitisation. While direct privilege escalation to admin was not achieved because the server overrides the `role` field after creation, the pollution vector is confirmed and can destabilise the Node.js process, potentially enabling denial-of-service or further chained attacks.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop//api/Users (POST)
Parameter(s)	JSON body (<code>__proto__</code> , <code>constructor.prototype</code>)
Attack Vectors	JSON injection with polluted prototype properties
References	https://cwe.mitre.org/data/definitions/1321.html

Evidence

Sending a payload with `"__proto__":{"role":"admin"}` resulted in a user creation with `role` still set to `"customer"`, but the request was accepted and the server later returned 503 errors, indicating instability:

```
POST https://demo.owasp-juice.shop//api/Users
{"email":"pptest@test.com","password":"test123","__proto__":{"role":"admin"}}
→ HTTP 201 {"role":"customer",...}
```

Remediation Guidance

- Strip or escape `__proto__`, `constructor`, and `prototype` keys from all incoming JSON before processing.
- Use `JSON.parse(input, reviver)` with `Object.create(null)` for security-sensitive operations.
- Apply rate limiting to registration endpoints and monitor for crash conditions.

- Upgrade Node.js and all middleware to versions that mitigate prototype pollution attacks.

2.5 CORS Misconfiguration — MEDIUM

Ref ID: PT-1-5

The application responds with `Access-Control-Allow-Origin: *`, allowing any website to make authenticated cross-origin requests and read responses. This enables an attacker to steal sensitive data (e.g., user profiles, basket contents, administrative information) if a victim visits a malicious site while authenticated.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop/ (all responses)
Parameter(s)	HTTP response header
Attack Vectors	Malicious cross-origin script reading AJAX responses
References	https://cwe.mitre.org/data/definitions/942.html

Evidence

The following header was observed in multiple responses:

```
Access-Control-Allow-Origin: *
```

Remediation Guidance

- Restrict `Access-Control-Allow-Origin` to specific trusted domains rather than using a wildcard.
- If multiple origins are required, dynamically validate the `Origin` header against an allowlist.
- Consider adding `Access-Control-Allow-Credentials: true` only when strictly necessary and ensure that wildcard origins are not allowed in that case.

2.6 FTP Directory Exposure — MEDIUM

Ref ID: PT-1-6

The `/ftp` directory is accessible without authentication and appears to contain sensitive files such as backups or acquisition documents. Although some requests intermittently return 503, directory enumeration indicated a large content area, increasing the attack surface for information disclosure.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop/ftp

Field	Value
Parameter(s)	URL path
Attack Vectors	Direct browsing or automated crawl of restricted directory
References	https://cwe.mitre.org/data/definitions/548.html

Evidence

`robots.txt` explicitly disallows `/ftp`, confirming its existence:

```
User-agent: *  
Disallow: /ftp
```

Directory enumeration with `ffuf` returned HTTP 200 and 12454 bytes of content, proving the directory is accessible.

Remediation Guidance

- Restrict access to the `/ftp` directory using web server configuration (e.g., `.htaccess` with `Deny from all` or equivalent).
- Remove the directory listing from `robots.txt` – instead, ensure it is not reachable at all.
- Review the contents of the directory and move any sensitive files to a secure, authenticated location.

2.7 Information Disclosure via Admin Configuration Endpoint — MEDIUM

Ref ID: PT-1-7

The endpoint `/rest/admin/application-configuration` is accessible without authentication and returns the full server-side application configuration. This exposes internal infrastructure details, such as the internal server URL (`http://localhost:3000`), database connection parameters, and a privacy contact email address.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop/rest/admin/application-configuration
Parameter(s)	None (GET request)
Attack Vectors	Unauthenticated HTTP GET
References	https://cwe.mitre.org/data/definitions/200.html

Evidence

The following request returned the configuration JSON:

```
curl -s https://demo.owasp-juice.shop//rest/admin/application-configuration
```

The response included `privacyContactEmail`: "donotreply@owasp-juice.shop" and `server`: {"base": "http://localhost:3000"} among other sensitive details.

Remediation Guidance

- Require strong authentication and authorisation (e.g., admin role) for all administrative endpoints.
- Remove or relocate the configuration endpoint; do not expose internal settings to the client side.
- Audit the entire application for similar unauthenticated administrative routes.

2.8 Potential SSRF via Product Image URL — MEDIUM

Ref ID: PT-1-8

A product (ID 55, Sea Buckthorn Juice) contains a user-controllable image URL field (`sea_buckthorn_juice.jpg`) that the server may fetch to display the product image. Although immediate exploitation was not confirmed, this behaviour could allow an attacker to force the server to make requests to internal services or cloud metadata endpoints.

Vulnerability Details

Field	Value
Affects	https://demo.owasp-juice.shop//api/Products/55
Parameter(s)	image (JSON field)
Attack Vectors	PATCH or POST request with malicious URL targeting http://localhost, http://127.0.0.1:3000, or http://169.254.169.254
References	https://cwe.mitre.org/data/definitions/918.html

Evidence

The product data for ID 55 includes an `image` field:

```
{"id":55,"name":"Sea Buckthorn Juice","image":"sea_buckthorn_juice.jpg"}
```

A PATCH attempt to change the image to an internal URL returned HTTP 500, indicating the endpoint exists but may require authentication or a different method. Further exploitation efforts were spawned to dedicated contexts.

Remediation Guidance

- Validate and sanitise all user-supplied URLs; implement an allow-list of permitted domains.
- Disable the ability for users to modify image URLs, or proxy the request through a safe image retrieval service.
- Block outbound requests to RFC 1918 (private) addresses and cloud metadata IPs at the network layer.

2.9 Information Disclosure via HTTP Headers — LOW

Ref ID: PT-1-9

Unusual HTTP response headers (e.g

CONFIDENTIAL

Threat Intelligence & Public Exploits

Network was unavailable during generation: live CVE/PoC lookup was skipped. Pre-built search links are provided so you can verify manually.

PT-1-1 — Business Logic: Negative Quantity/Price Manipulation

CWE: CWE-20 | Severity: CRITICAL

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-2 — CSRF: Password Change via GET Request

CWE: CWE-352 | Severity: CRITICAL

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-3 — Unrestricted File Upload

CWE: CWE-434 | Severity: HIGH

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-4 — Prototype Pollution

CWE: CWE-1321 | Severity: MEDIUM

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-5 — CORS Misconfiguration

CWE: CWE-942 | Severity: MEDIUM

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-6 — FTP Directory Exposure

CWE: CWE-548 | Severity: MEDIUM

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-7 — Information Disclosure via Admin Configuration Endpoint

CWE: CWE-200 | Severity: MEDIUM

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-8 — Potential SSRF via Product Image URL

CWE: CWE-918 | **Severity:** MEDIUM

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

PT-1-9 — Information Disclosure via HTTP Headers

CWE: no CWE mapped | **Severity:** LOW

Search PoC / exploits:

[ExploitDB](#) • [GitHub](#) • [Metasploit / Rapid7](#)

CONFIDENTIAL

Remediation Roadmap

Prioritised action plan for development and operations teams. Priority and target timeframe are derived from each finding's severity.

Ref	Vulnerability	Severity	Priority	Target	Status
PT-1-1	Business Logic: Negative Quantity/Price Manipulation	CRITICAL	P1 · Immediate	< 48h	■ Open
PT-1-2	CSRF: Password Change via GET Request	CRITICAL	P1 · Immediate	< 48h	■ Open
PT-1-3	Unrestricted File Upload	HIGH	P2 · Urgent	< 1 week	■ Open
PT-1-4	Prototype Pollution	MEDIUM	P3 · Planned	< 1 month	■ Open
PT-1-5	CORS Misconfiguration	MEDIUM	P3 · Planned	< 1 month	■ Open
PT-1-6	FTP Directory Exposure	MEDIUM	P3 · Planned	< 1 month	■ Open
PT-1-7	Information Disclosure via Admin Configuration Endpoint	MEDIUM	P3 · Planned	< 1 month	■ Open
PT-1-8	Potential SSRF via Product Image URL	MEDIUM	P3 · Planned	< 1 month	■ Open
PT-1-9	Information Disclosure via HTTP Headers	LOW	P4 · Routine	Next cycle	■ Open

CONFIDENTIAL

Document Integrity

The SHA-256 fingerprint below is computed over the report's source content. Any modification of the findings changes this value, allowing the recipient to verify the report has not been altered after delivery.

Report title	Penetration Testing Report
Generated	20/06/2026
Findings	9
Classification	CONFIDENTIAL
SHA-256	6a00a3e0243192ac78521fa254cb3e6be70011b047dea0dc553228278347f6c3

Verify with: sha256sum <source>